LABORATUVAR 5 · GENEL SÜRÜM · Şişeleme Hattı

# SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

**Kavram: SBOM** = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

## Verilen zafiyet kaydı

| | |
|---|---|
| **Bileşen** | Component X (PLC firmware kütüphanesi) |
| **Sürüm** | 2.4 |
| **CVE** | CVE-XXXX-XXXX |
| **Önem** | Critical (CVSS 9.8) |
| **Yama** | Mevcut |

## Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

Uç kontrol yapılmalıdır:
Component X'in kurulu olduğu SBOM veya envanterden doğrulanır.
Kurulu sürüm 2.4'ün etkilenen sürümler arasında olup olmadığı kontrol edilir.
Zafiyetli işlevin etkinliği ve saldırı yolunun erişilebilirliği değerlendirilir.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

Yalnızca CVSS 9.8 puanına dayanarak karar verilmez. Aktif istismar, fiziksel sonuç ve emniyet sisteminin bütünlüğü değerlendirilir. Güvenli çalışma doğrulanamıyorsa hat kontrollü durdurulur.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Once üretici uyumluluğu kontrol edilir. Gerçek donanım ve yazılım yapılandırmasını temsil eden izole test ortamında denenir. Başarılı testten sonra yedek ve geri dönüş planıyla bakım zamanında uygulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Değişiklik notları ve bağımlılıklar incelenir. Emniyet mantığı, haberleşme, giriş–çıkışlar veya tepki süreleri etkileniyorsa ilgili fonksiyonlar yeniden doğrulanır. Yalnızca hattın çalışması yeterli kanıt değildir.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

İlgili servis kapatılır veya izole edilir; uzak erişim ve hesap yetkileri sınırlandırılır, kayıtlar izlenir. Önlemlerle risk yeterince azaltılamıyorsa çalışma sürdürülmez.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.